

SOC/L1 - 4.4. Mitre

Task 1 - Introduction

MITRE is a not-for-profit organization that conducts research and development across a range of domains, including cyber security, artificial intelligence, healthcare, and space systems.

In this room, we will focus on MITRE's cyber security frameworks and resources, including MITRE ATT&CK, the CAR Knowledge Base, D3FEND, MITRE Engage

Task 2 - ATT&CK® Framework

The [MITRE ATT&CK®\(opens in new tab\)](#) framework is "a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations. The ATT&CK knowledge base is used as a foundation for the development of specific threat models and methodologies in the private sector, in government, and in the cyber security product and service community".

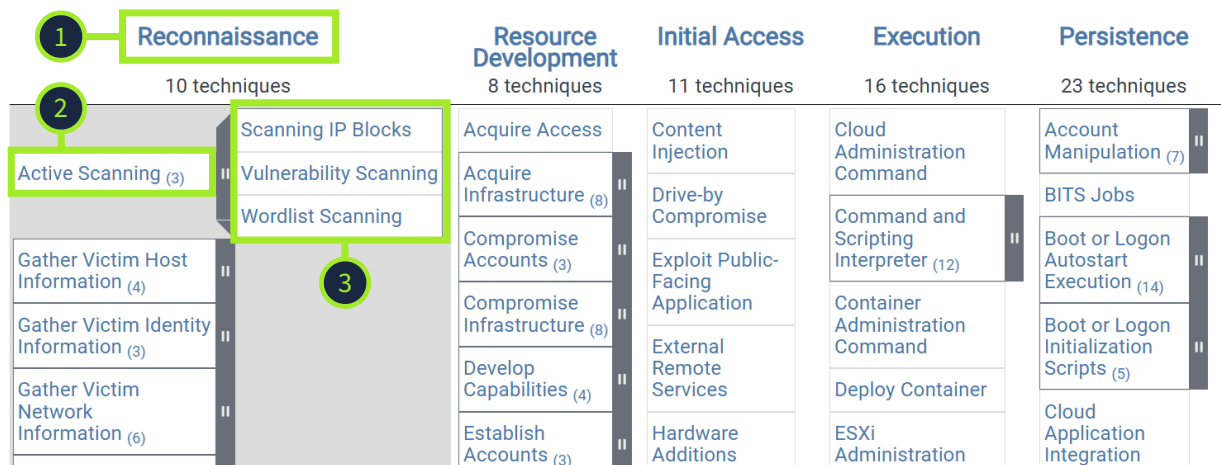
In 2013, MITRE recognized the need to document and categorize the standard tactics, techniques, and procedures (TTPs) used by advanced persistent threat (APT) groups. To better understand how adversaries operate, it's helpful to break down what each part of TTP represents:

- [Tactic\(opens in new tab\)](#): An adversary's goal or objective. The "why" of an attack.
- [Technique\(opens in new tab\)](#): How an adversary achieves their goal or objective.
- Procedure: The implementation or how the technique is executed.

ATT&CK Matrix

The [MITRE ATT&CK Matrix\(opens in new tab\)](#) is a powerful visual representation of all tactics and techniques that exist within the framework. You can also utilize the [ATT&CK Navigator\(opens in new tab\)](#), a handy tool for annotating and exploring matrices. The tactics are represented across the top of the matrix. Each tactic contains techniques nested below, which can be expanded to reveal sub-techniques.

1. **Tactic:** Let's say that an attacker wants to perform Reconnaissance on their target. This is the attacker's goal.
2. **Technique:** They may utilize the Active Scanning technique. This is how they achieve their Reconnaissance goal.
3. **Sub-technique:** Active Scanning comprises three specific methods: Scanning IP Blocks, Vulnerability Scanning, or Wordlist Scanning.



Answer the questions below

What Tactic does the Phishing technique belong to in the ATT&CK Matrix? Initial Access

Home > Techniques > Enterprise > Phishing

Phishing

Sub-techniques (4)

Adversaries may send phishing messages to gain access to victim systems. All forms of phishing are electronically delivered social engineering. Phishing can be targeted, known as spearphishing. In spearphishing, a specific individual, company, or industry will be targeted by the adversary. More generally, adversaries can conduct non-targeted phishing, such as in mass malware spam campaigns.

Adversaries may send victims emails containing malicious attachments or links, typically to execute malicious code on victim systems. Phishing may also be conducted via third-party services, like social media platforms. Phishing may also involve social engineering techniques, such as posing as a trusted source, as well as evasive techniques such as removing or manipulating emails or metadata/headers from compromised accounts being abused to send messages (e.g., [Email Hiding Rules](#)).^{[1][2]} Another way to accomplish this is by [Email Spoofing](#)^[3] the identity of the sender, which can be used to fool both the human recipient as well as automated security tools,^[4] or by including the intended target as a party to an existing email thread that includes malicious files or links (i.e., "thread hijacking").^[5]

ID: T1566

Sub-techniques: T1566.001, T1566.002, T1566.003, T1566.004

① **Tactic:** Initial Access

① **Platforms:** Identity Provider, Linux, Office Suite SaaS, Windows, macOS

Contributors: Liora Itkin; Liran Ravich, CardinalOps; Ohad Zaidenberg, @ohad_mz; Philip Winther; Scott Cook, Capital One

Version: 2.7

Created: 02 March 2020

Last Modified: 12 May 2026

Which ID is associated with the Create Account technique? T1136

Create Account

Sub-techniques (3)

Adversaries may create an account to maintain access to victim systems.^[1] With a sufficient level of access, creating such accounts may be used to establish secondary credentialed access that do not require persistent remote access tools to be deployed on the system.

Accounts may be created on the local system or within a domain or cloud tenant. In cloud environments, adversaries may create accounts that only have access to specific services, which can reduce the chance of detection.

ID: T1136

Sub-techniques: [T1136.001](#), [T1136.002](#), [T1136.003](#)

① **Tactic:** [Persistence](#)

① **Platforms:** Containers, ESXi, IaaS, Identity Provider, Linux, Network Devices, Office Suite, SaaS, Windows, macOS

Contributors: Austin Clark, @c2defense; Microsoft Threat Intelligence Center (MSTIC); Praetorian

Version: 2.6

Created: 14 December 2017

Last Modified: 24 October 2025

Task 3 - Why ATT&CK Matters

ATT&CK helps bridge the gap between threat intelligence and defensive operations. A threat report might describe what an attacker did, but not how to turn that information into usable detection measures. Through mapping threat activity to TTPs, defenders can translate intelligence into real detection logic, queries, and playbooks.

Who	Their Goal	How They Use ATT&CK
Cyber Threat Intelligence (CTI) Teams	Collect and analyze threat information to improve an organization's security posture	Map observed threat actor behavior to ATT&CK TTPs to create profiles that are actionable across the industry
SOC Analysts	Investigate and triage security alerts	Link activity to tactics and techniques to provide detailed context for alerts and prioritize incidents
Detection Engineers	Design and improve detection systems	Map SIEM/EDR and other rules to ATT&CK to ensure better detection efforts
Incident Responders	Respond to and investigate security incidents	Map incident timelines to MITRE tactics and techniques to better visualize the attack.
Red & Purple Teams	Emulate adversary behavior to test and improve defenses	Build emulation plans and exercises aligned with techniques and known group operations

Answer the questions below

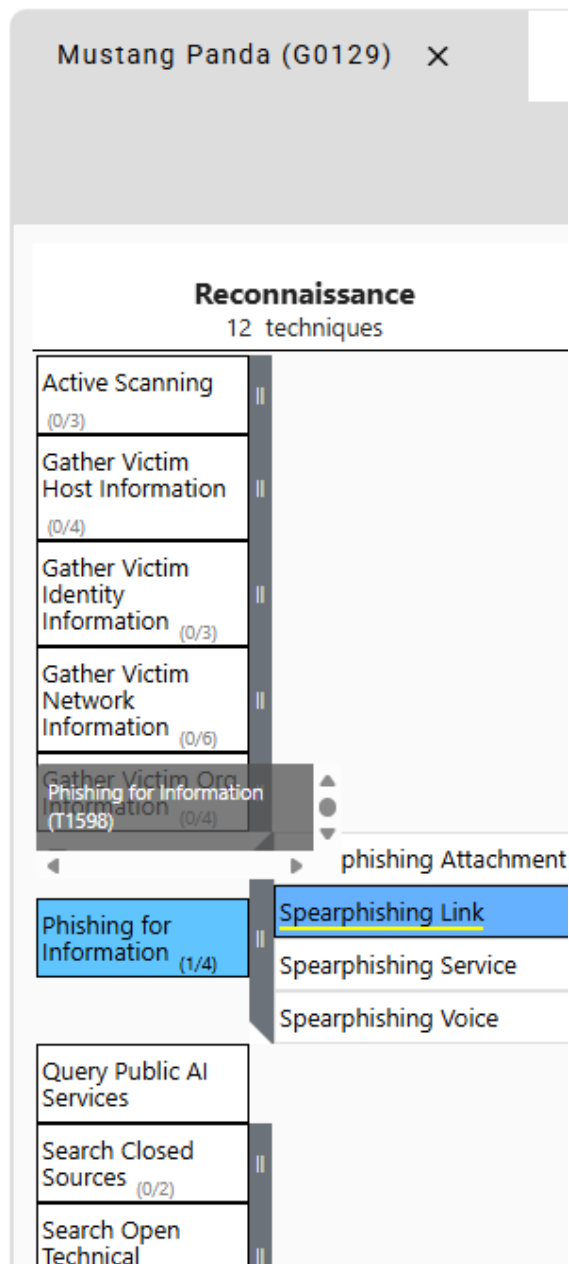
In which country is Mustang Panda based? China

[Home](#) > [Groups](#) > Mustang Panda

Mustang Panda

Mustang Panda is a China-based cyber espionage threat actor that has been conducting operations since at least 2012. Mustang Panda has been known to use tailored phishing lures and decoy documents to deliver malicious payloads. Mustang Panda has targeted government, diplomatic, and non-governmental organizations, including think tanks, religious institutions, and research entities, across the United States, Europe, and Asia, with notable activity in Russia, Mongolia, Myanmar, Pakistan, and Vietnam. ^{[1][2][3][4][5][6][7][8][9][10][11][12][13]}

Which ATT&CK technique ID maps to Mustang Panda's Reconnaissance tactics?
T1598 (click enterprise layer)



Which software is Mustang Panda known to use for Access Token Manipulation? Cobalt Strike

MITRE ATT&CK®				
Search				
Groups				
MuddyWater				
Mustang Panda	S1236	CLAIMLOADER	[27][28]	Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder, Deobfuscate/Decode Files or Information, Execution Guardrails: Mutual Exclusion, Hide Artifacts: Hidden Files and Directories, Hijack Execution Flow: DLL, Inter-Process Communication: Component Object Model, Masquerading: Match Legitimate Resource Name or Location, Native API, Obfuscated Files or Information: Dynamic API Resolution, Scheduled Task/Job: Scheduled Task, User Execution: Malicious File
Mustard Tempest				
Naikon				
NEODYMIUM				
Nomadic Octopus				
OilRig	S0154	Cobalt Strike	[2][3][5][15][20][9][35]	Abuse Elevation Control Mechanism: Sudo and Sudo Caching, Abuse Elevation Control Mechanism: Bypass User Account Control, Access Token Manipulation: Parent PID Spoofing, Access Token Manipulation: Token Impersonation/Theft, Access Token Manipulation: Make and Impersonate Token, Account Discovery: Domain Account, Application Layer Protocol: DNS, Application Layer Protocol: Web Protocols, Application Layer Protocol: File Transfer Protocols, BITS Jobs, Browser
Orangeworm				
Patchwork				
PittyTiger				

Task 4 - ATT&CK for Threat Intelligence

Scenario: Your task is to use ATT&CK to gather intelligence on APT groups known to target this sector, identify their tactics and techniques, and assess any potential gaps in your defensive coverage.

Answer the questions below

Which APT group has targeted the aviation sector and has been active since at least 2013? APT33

MITRE ATT&CK®				
Search				
Groups				
Overview				
admin@338				
Agrius				
Ajax Security Team				
Akira				
ALLANITE				
Andariel				
Aoqin Dragon				
AppleJews				
APT-C-23				
				some characteristics with APT30, the two groups do not appear to be exact matches.
	G0050	APT32	SeaLotus, OceanLotus, APT-C-00, Canvas Cyclone, BISMUTH	APT32 is a suspected Vietnam-based threat group that has been active since at least 2014. The group has targeted multiple private sector industries as well as foreign governments, dissidents, and journalists with a strong focus on Southeast Asian countries like Vietnam, the Philippines, Laos, and Cambodia. They have extensively used strategic web compromises to compromise victims.
	G0064	APT33	HOLMIUM, Elfin, Peach Sandstorm	APT33 is a suspected Iranian threat group that has carried out operations since at least 2013. The group has targeted organizations across multiple industries in the United States, Saudi Arabia, and South Korea, with a particular interest in the aviation and energy sectors.

Which ATT&CK sub-technique used by this group is a key area of concern for companies using Office 365? Cloud Accounts

MITRE ATT&CK®					
Matrices ▾ Tactics ▾ Techniques ▾ Defenses ▾ C 365 1/1 ^ v ≡ × contribute					
Search Q					
GROUPS	APT32	Enterprise	T1204	Credentials in Files	
				LaZagne to gather credentials. ^{[4][6]}	
				.006	Unsecured Credentials: Group Policy Preferences
	APT33	Enterprise	T1078	.001	User Execution: Malicious Link
				APT33 has lured users to click links to malicious HTML applications delivered via spearphishing emails. ^{[1][4]}	
APT37	APT38	Enterprise	T1078	.002	User Execution: Malicious File
				APT33 has used malicious e-mail attachments to lure victims into executing malware. ^[3]	
				Valid Accounts	
	APT39	Enterprise	T1078	APT33 has used valid accounts for initial access and privilege escalation. ^{[2][6]}	
				.004	Cloud Accounts
APT41	APT42	Enterprise	T1078	APT33 has used compromised Office 365 accounts in tandem with Ruler in an attempt to gain control of endpoints. ^[3]	
	APT5	Enterprise	T1078		
Aquatic Panda	APT5	Enterprise	T1078		
	APT5	Enterprise	T1078		

According to ATT&CK, what tool is linked to the APT group and the sub-technique you identified? Ruler

MITRE ATT&CK®					
Matrices ▾ Tactics ▾ Techniques ▾ Defenses ▾ C cloud 1/3 ^ v ≡ × contribute					
Search Q					
GROUPS	APT32	Enterprise	T1204	Credentials in Files	
				LaZagne to gather credentials. ^{[4][6]}	
				.006	Unsecured Credentials: Group Policy Preferences
	APT33	Enterprise	T1078	.001	User Execution: Malicious Link
				APT33 has lured users to click links to malicious HTML applications delivered via spearphishing emails. ^{[1][4]}	
APT37	APT38	Enterprise	T1078	.002	User Execution: Malicious File
				APT33 has used malicious e-mail attachments to lure victims into executing malware. ^[3]	
				Valid Accounts	
	APT39	Enterprise	T1078	APT33 has used valid accounts for initial access and privilege escalation. ^{[2][6]}	
				.004	Cloud Accounts
APT41	APT42	Enterprise	T1078	APT33 has used compromised Office 365 accounts in tandem with Ruler in an attempt to gain control of endpoints. ^[3]	
	APT5	Enterprise	T1078		
Aquatic Panda	APT5	Enterprise	T1078		
	APT5	Enterprise	T1078		

Which mitigation strategy advises removing inactive or unused accounts to reduce exposure to this sub-technique? User Account Management

identify attacker behaviors and create detections for specific **TTPs (Tactics, Techniques, and Procedures)**. CAR provides:

- Detection logic for adversary behaviors.
- Explanations of how and why each detection works.
- Example queries for security tools such as **Splunk** and **LogPoint**.
- Pseudocode to describe detection logic in a simple format.
- Unit tests to validate analytics when available.

Each CAR analytic maps to related **MITRE ATT&CK tactics and techniques**. For example, **CAR-2020-09-001: Scheduled Task - File Access** includes detection guidance and SIEM query examples. **CAR** helps SOC analysts and threat hunters convert **MITRE ATT&CK techniques into practical detections** by providing tested analytics, queries, and detection strategies.

Answer the questions below

Which ATT&CK Tactic is associated with CAR-2019-07-001 (opens in new tab)?
Defense Evasion

The screenshot shows a web browser window with the URL <https://car.mitre.org/analytics/CAR-2019-07-001/>. The page title is "CAR-2019-07-001: Access Permission Modification".

The main content area includes a description: "Adversaries sometimes modify object access rights at the operating system level. There are varying motivations behind this action - they may not want some files/objects to be changed on systems for persistence reasons and therefore provide admin only rights; also, they may want files to be accessible with lower levels of permissions." and a note: "Note - this analytic references file permissions, which are not currently in the CAR data model."

On the right side, there is a metadata box with the following information:

- Submission Date:** 2019/07/08
- Update Date:**
- Information Domain:** Host
- Data Subtypes:** File
- Analytic Type:** Situational Awareness
- Applicable Platforms:** Windows, Linux, macOS
- Contributors:** Meric Degirmenci, MITRE

Below the description, the section "ATT&CK Detections" contains a table:

Technique	Subtechnique(s)	Tactic(s)	Level of Coverage
File and Directory Permissions Modification	Windows File and Directory Permissions Modification , Linux and Mac File and Directory Permissions Modification	Defense Evasion	Moderate

What is the Analytic Type for Access Permission Modification? Situational Awareness

Submission Date: 2019/07/08
Update Date:
Information Domain: Host
Data Subtypes: File
Analytic Type: Situational Awareness
Applicable Platforms: Windows, Linux, macOS
Contributors: Meric Degirmenci, MITRE

Task 6 - MITRE D3FEND Framework

D3FEND (Detection, Denial, and Disruption Framework Empowering Network Defense) is a defensive cybersecurity framework that defines and organizes **security countermeasures** against attacker techniques. It provides:

- A **matrix of defensive tactics and techniques**.
- Unique technique IDs for security controls.
- Guidance on how defenses work and how to implement them.

Example:

- **Credential Rotation (D3-CRO):** Regularly changing passwords to prevent attackers from reusing stolen credentials.

D3FEND helps defenders understand the relationship between **attacker techniques (MITRE ATT&CK)** and **defensive actions**, allowing organizations to build stronger security controls.

Answer the questions below

Which sub-technique of User Behavior Analysis (opens in new tab) would you use to analyze the geolocation data of user logon attempts? User Geolocation Logon Pattern Analysis

https://d3fend.mitre.org/technique/d3f:UserBehaviorAnalysis/

geolocation 2/3

Technique Subclasses

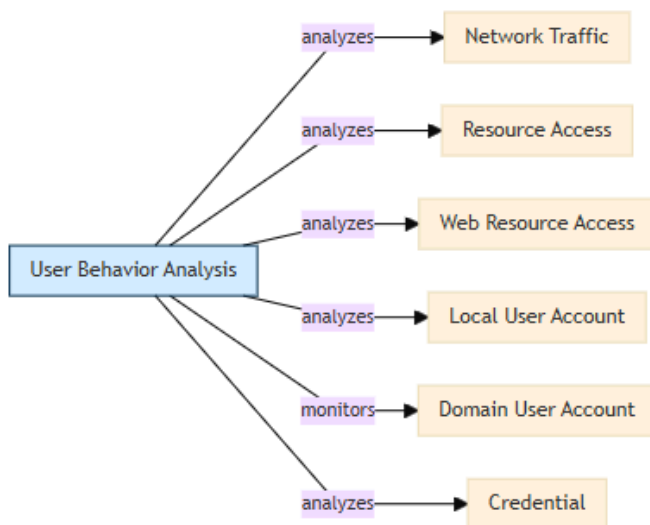
There are 12 techniques in this category, **User Behavior Analysis**.

Name	ID	Definition	Synonyms
User Behavior Analysis	D3-UBA	User behavior analytics ("UBA") as defined by Gartner, is a cybersecurity process about detection of insider threats, targeted attacks, and financial fraud. UBA solutions look at patterns of human behavior, and then apply algorithms and statistical analysis to detect meaningful anomalies from those patterns-anomalies that indicate potential threats.' Instead of tracking devices or security events, UBA tracks a system's users. Big data platforms are increasing UBA functionality by allowing them to analyze petabytes worth of data to detect insider threats and advanced persistent threats.	UBA , and Credential Monitoring
- User Geolocation Logon Pattern Analysis	D3-UGLPA	Monitoring geolocation data of user logon attempts and comparing it to a baseline user behavior profile to identify anomalies in logon location.	

Which digital artifact does this sub-technique rely on analyzing? Network Traffic

Artifact Relationships:

This defensive technique is related to specific artifacts. Click the artifact node for more information.



Task 7 - Other MITRE Projects

Emulation Plans: MITRE's **Adversary Emulation Library** provides step-by-step guides for simulating real-world attacks from known threat groups. It helps security teams test their defenses using realistic attack scenarios.

Caldera: **MITRE Caldera** is an automated adversary emulation platform based on the **MITRE ATT&CK framework**. It allows teams to simulate attacker behavior test detection capabilities, and practice incident response in a controlled environment.

AADAPT: **AADAPT (Adversarial Actions in Digital Asset Payment Technologies)** is a threat framework focused on digital asset systems. It helps defenders understand attacks targeting **blockchain, smart contracts, and digital wallets**.

ATLAS: **ATLAS (Adversarial Threat Landscape for Artificial-Intelligence Systems)** is a framework focused on **AI and machine learning security threats**. It documents AI attack techniques, vulnerabilities, and defense strategies.

Answer the questions below

What technique ID is associated with Scrape Blockchain Data (opens in new tab) in the AADAPT framework? ADT3025

Scrape Blockchain Data

Summary

An adversary may scrape blockchain data to reveal sensitive information for exploitation.

ID: ADT3025

Tactic: [Collection](#)

Blockchain scraping involves extracting and compiling data directly from the public ledger of a blockchain network. While transactions themselves may be anonymized, other elements like wallet addresses, timestamps, and associated smart contract interactions can paint a revealing picture.

Which tactic does LLM Prompt Obfuscation (opens in new tab) belong to in the ATLAS framework? Defense Evasion

LLM Prompt Obfuscation

Adversaries may hide or otherwise obfuscate prompt injections or retrieval content to avoid detection from humans, large language model (LLM) guardrails, or other detection mechanisms.

For text inputs, this may include modifying how the instructions are rendered such as small text, text colored the same as the background, or hidden HTML elements. For multi-modal inputs, malicious instructions could be hidden in the data itself (e.g. in the pixels of an image) or in file metadata (e.g. EXIF for images, ID3 tags for audio, or document metadata).

Inputs can also be obscured via an encoding scheme such as base64 or rot13. This may bypass LLM guardrails that identify malicious content and may not be as easily identifiable as malicious to a human in the loop.

ID: AML.T0068

Tactics: Defense
Evasion

Maturity:
• Demonstrated

Platforms:
• Agentic AI
• Generative AI

Number of Case Studies:
8